

# **Actividad 2: Análisis de servicios de seguridad (X.800 y RFC 4949)**

**CNOV SEGURIDAD INFORMATICA**  
**Profesor: Servando López Contreras**

**Carrera: ITI**

**Alumno:**

**Enrique Alvarez Aquino – 177071**

## introducción:

Actualmente, la seguridad de la información es un aspecto muy importante dentro de los sistemas informáticos y de comunicación, ya que permite proteger los datos contra accesos no autorizados, modificaciones indebidas o pérdidas de información. Debido al crecimiento del uso de redes y servicios digitales, surgió la necesidad de establecer normas y documentos que ayuden a comprender y aplicar correctamente la seguridad en estos entornos. Entre estos documentos destacan el X.800 y el RFC 4949, los cuales aportan bases fundamentales para el estudio de la seguridad informática.

El X.800, también conocido como *Security Architecture for OSI*, fue desarrollado por la International Organization for Standardization (ISO) como parte del modelo de referencia OSI. Este estándar tiene como objetivo principal definir una arquitectura de seguridad que permita identificar los servicios necesarios para proteger la información durante su transmisión en una red. El X.800 clasifica la seguridad en distintos servicios, como la autenticación, el control de acceso, la confidencialidad, la integridad y el no repudio, además de describir mecanismos de seguridad como el cifrado y las firmas digitales. Esta clasificación ayuda a comprender de forma más clara cómo se puede proteger la información dentro de los sistemas de comunicación.

Por otro lado, el RFC 4949, conocido como *Internet Security Glossary*, fue creado con la finalidad de unificar los términos y conceptos relacionados con la seguridad informática. A diferencia del X.800, este documento no se enfoca en la arquitectura de seguridad, sino en ofrecer definiciones claras y precisas de los conceptos más utilizados en este campo. El RFC 4949 es de gran utilidad, ya que facilita la comunicación entre estudiantes, profesionales y especialistas, evitando confusiones al momento de analizar o implementar medidas de seguridad.

## Escenario 01.

En múltiples incidentes atribuidos al grupo LockBit, organizaciones públicas y privadas han sufrido el cifrado masivo de servidores tras un acceso inicial no autorizado. Antes de ejecutar el ransomware, los atacantes exfiltraron información sensible y posteriormente amenazaron con su publicación, evidenciando un compromiso simultáneo de la confidencialidad, la integridad y la disponibilidad. Desde el enfoque del RFC 4949, el incidente se clasifica como un multi-stage attack con data breach y availability attack, donde la indisponibilidad del sistema es solo una fase final del daño. La ausencia de respaldos inmutables y de detección temprana permitió que el impacto fuera total.

| <i>Elemento</i>                            | <i>Respuesta</i>                                                                                                                                                                                                                                                                         |
|--------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Confidencialidad, Integridad y Disponibilidad.                                                                                                                                                                                                                                           |
| <i>Definicion(es) aplicable(s) RFC4949</i> | <b>Multi-stage attack:</b> Serie de ataques donde cada paso ayuda al siguiente<br><b>Data breach:</b> Acceso o extracción de datos por parte de alguien no autorizado.<br><b>Availability attack:</b> Acción que impide que los usuarios legítimos accedan a la información o servicios. |
| <i>Tipo de amenaza</i>                     | <b>Externa :</b> El agente de amenaza (LockBit) es un grupo externo que ataca desde fuera del perímetro de la red con fines de lucro                                                                                                                                                     |
| <i>Vector de ataque</i>                    | Acceso inicial no autorizado (explotación de vulnerabilidades o phishing).                                                                                                                                                                                                               |
| <i>Impacto técnico/operativo</i>           | Cifrado masivo y parálisis de la organización.                                                                                                                                                                                                                                           |
| <i>Medida de control recomendada</i>       | Respaldos inmutables y monitoreo de red.                                                                                                                                                                                                                                                 |

## Escenario 02.

En diversos casos documentados, bases de datos completas quedaron accesibles públicamente debido a errores de configuración en servicios de almacenamiento en la nube. No existió una explotación técnica sofisticada, sino una falla en el control de acceso, lo que derivó directamente en la pérdida de confidencialidad de los datos. El RFC 4949 describe este tipo de incidentes como misconfiguration y exposure, subrayando que la amenaza no siempre implica malware o intrusión activa. El impacto suele ser legal y reputacional, aun cuando no se pueda demostrar acceso malicioso.

| <b>Elemento</b>                            | <b>Respuesta</b>                                                                                                                                                                        |
|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Confidencialidad                                                                                                                                                                        |
| <i>Definicion(es) aplicable(s) RFC4949</i> | <b>Misconfiguration:</b> Error en los ajustes del sistema que deja brechas de seguridad.<br><b>Exposure:</b> Condición donde datos sensibles son visibles para personas no autorizadas. |
| <i>Tipo de amenaza</i>                     | <b>Interna:</b> Se origina por un error de un administrador de la propia organización (falla humana), no por un ataque externo.                                                         |
| <i>Vector de ataque</i>                    | <b>Configuración incorrecta:</b> Falta de políticas de control de acceso o permisos "públicos" por error en la consola de la nube.                                                      |
| <i>Impacto técnico/operativo</i>           | Fuga de información sensible, multas legales y pérdida de confianza de los clientes.                                                                                                    |
| <i>Medida de control recomendada</i>       | <b>Auditorías de configuración:</b> Escaneo automático de permisos .                                                                                                                    |

### Escenario 03.

Un proveedor legítimo de software fue comprometido y distribuyó una actualización que incluía código malicioso, afectando a cientos de organizaciones que confiaban en él. Este escenario refleja una violación grave de la integridad de los sistemas y, en muchos casos, de la confidencialidad, al permitir accesos no autorizados posteriores. El RFC 4949 lo identifica como supply chain attack, destacando el abuso de relaciones de confianza. El daño es particularmente crítico porque rompe el supuesto de legitimidad del software firmado.

| <b>Elemento</b>                            | <b>Respuesta</b>                                                                                           |
|--------------------------------------------|------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Integridad, Confidencialidad, Autenticidad                                                                 |
| <i>Definicion(es) aplicable(s) RFC4949</i> | <b>Supply Chain Attack:</b> Ataque que compromete a una organización a través de sus proveedores o socios. |

|                                      |                                                                                                                           |
|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
|                                      | <b>Abuso de Confianza:</b> Explotación de una relación legítima para infiltrarse en sistemas protegidos.                  |
| <i>Tipo de amenaza</i>               | <b>Externa:</b> Ejecutada por un agente externo que compromete al proveedor para llegar a sus clientes.                   |
| <i>Vector de ataque</i>              | Inyección de código malicioso, Infiltración en el ciclo de desarrollo o servidores de actualización del proveedor.        |
| <i>Impacto técnico/operativo</i>     | Acceso masivo a redes protegidas, persistencia a largo plazo y pérdida total de confianza en los proveedores de software. |
| <i>Medida de control recomendada</i> | Monitoreo de comportamiento sospechoso (EDR) y aplicación de políticas de "Zero Trust" (Desconfianza Cero)                |

#### Escenario 04.

Mediante campañas de phishing, atacantes obtuvieron credenciales válidas y accedieron a sistemas corporativos durante meses sin levantar alertas. Aunque la autenticación funcionó técnicamente, el servicio de autenticación fue comprometido al basarse en credenciales robadas, afectando también el control de acceso. Según el RFC 4949, se trata de un credential compromise con authentication failure conceptual, no técnica. La falta de MFA y de monitoreo de comportamiento facilitó la persistencia del atacante.

| <i>Elemento</i>                            | <i>Respuesta</i>                                                                                                                                                                                                      |
|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Autenticación, Control de Acceso, Confidencialidad                                                                                                                                                                    |
| <i>Definición(es) aplicable(s) RFC4949</i> | <b>•Credential Compromise:</b> Robo de nombres de usuario y contraseñas.<br><b>Authentication Failure (Conceptual):</b> El sistema valida la clave correctamente, pero la persona que la usa no es el dueño legítimo. |
| <i>Tipo de amenaza</i>                     | <b>Externa:</b> Realizada por atacantes externos que buscan infiltrarse mediante engaños.                                                                                                                             |

|                                      |                                                                                                                                                               |
|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Vector de ataque</i>              | Engaño al usuario para que entregue sus credenciales a través de sitios o correos falsos.-Phising                                                             |
| <i>Impacto técnico/operativo</i>     | Acceso prolongado y silencioso a la red corporativa, robo de datos y posibilidad de escalar privilegios.                                                      |
| <i>Medida de control recomendada</i> | Autenticación de Múltiple Factor (MFA):<br>Añadir una capa extra de seguridad.<br>Análisis de Comportamiento (UEBA):<br>Detectar inicios de sesión inusuales. |

### Escenario 05.

En ataques de ransomware avanzados, los atacantes eliminaron o cifraron los respaldos antes de afectar los sistemas productivos. Este hecho compromete directamente la disponibilidad y la integridad de la información, al impedir la recuperación. El RFC 4949 clasifica este comportamiento como data destruction y availability attack, evidenciando intención deliberada de maximizar el daño. La inexistencia de respaldos offline o inmutables convierte el incidente en catastrófico.

| <i>Elemento</i>                            | <i>Respuesta</i>                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Confidencialidad, Integridad, Disponibilidad, Responsabilidad (Accountability)                                                                                                                                                                                                                                                                                                                   |
| <i>Definicion(es) aplicable(s) RFC4949</i> | <b>Multi-stage Attack:</b> Serie de ataques relacionados donde cada etapa sienta las bases para la siguiente.<br><b>Data Breach:</b> Entrada no autorizada que resulta en la pérdida de confidencialidad.<br><b>Availability Attack:</b> Acción que impide el uso legítimo de los recursos del sistema.<br><b>Ransomware:</b> Malware que impide el acceso a datos hasta que se paga un rescate. |
| <i>Tipo de amenaza</i>                     | <b>Interna :</b> Ejecutada por un agente de amenaza activo (LockBit) mediante un ataque activo para obtener ganancias económicas ilícitas.                                                                                                                                                                                                                                                       |
| <i>Vector de ataque</i>                    | Acceso inicial no autorizado<br>Generalmente a través de vulnerabilidades en servicios expuestos                                                                                                                                                                                                                                                                                                 |

|                                      |                                                                                                                                                                                                                      |
|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                      | (RDP/VPN), credenciales comprometidas (Phishing) o explotación de vulnerabilidades de software no parcheadas.                                                                                                        |
| <i>Impacto técnico/operativo</i>     | Cifrado de archivos (pérdida de integridad/disponibilidad) y robo de datos.                                                                                                                                          |
| <i>Medida de control recomendada</i> | Respaldo Inmutable: Implementar con copias de seguridad "fuera de línea" o protegidas contra escritura.<br>Detección Temprana (EDR/XDR): Para identificar el movimiento lateral y la exfiltración antes del cifrado. |

### Escenario 06.

Un empleado con acceso legítimo extrajo bases de datos completas y las vendió a terceros, sin explotar vulnerabilidades técnicas. El servicio afectado fue principalmente la confidencialidad, junto con fallas en el control de acceso por exceso de privilegios. El RFC 4949 define este escenario como insider threat, destacando que el riesgo interno puede ser tan grave como el externo. La carencia de monitoreo y de políticas de mínimo privilegio fue determinante.

| <b>Elemento</b>                            | <b>Respuesta</b>                                                                                                                                                                                                 |
|--------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Confidencialidad, Control de Acceso, Responsabilidad (Accountability)                                                                                                                                            |
| <i>Definición(es) aplicable(s) RFC4949</i> | <b>Insider Threat:</b> Amenaza que proviene de una persona con acceso autorizado y conocimiento de la organización.<br><b>Privilege Abuse:</b> Uso de derechos de acceso para fines distintos a los autorizados. |
| <i>Tipo de amenaza</i>                     | <b>Interna :</b> Realizada por un miembro de la organización que actúa deliberadamente para causar daño o lucro personal..                                                                                       |
| <i>Vector de ataque</i>                    | Exceso de privilegios, el empleado tiene más permisos de los necesarios para su función, facilitando la extracción masiva de datos.                                                                              |
| <i>Impacto técnico/operativo</i>           | Pérdida de propiedad intelectual, ventajas competitivas y graves                                                                                                                                                 |

|                                      |                                                                                                                  |
|--------------------------------------|------------------------------------------------------------------------------------------------------------------|
|                                      | consecuencias legales por incumplimiento de privacidad                                                           |
| <i>Medida de control recomendada</i> | Principio de Mínimo Privilegio Dar solo el acceso necesario, monitorear y bloquear la salida de datos sensibles. |

### Escenario 07.

Tras un ataque, los registros del sistema quedaron cifrados o alterados, impidiendo reconstruir la secuencia de eventos. Esto compromete la integridad de los datos y el no repudio, ya que no es posible demostrar qué ocurrió ni quién fue responsable. Desde el RFC 4949, se trata de una violación de evidentiary integrity y del audit trail. El impacto no solo es técnico, sino también probatorio y legal.

| <b>Elemento</b>                            | <b>Respuesta</b>                                                                                                                                                                                                           |
|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Integridad, No Repudio, Responsabilidad.                                                                                                                                                                                   |
| <i>Definicion(es) aplicable(s) RFC4949</i> | <b>Audit Trail:</b> Conjunto de registros que permiten seguir la cronología de eventos de un sistema.<br><b>Evidentiary Integrity:</b> Calidad de los datos que permite su uso como prueba legal sin haber sido alterados. |
| <i>Tipo de amenaza</i>                     | <b>Externa:</b> Acción deliberada de un atacante para evadir la detección y la justicia.                                                                                                                                   |
| <i>Vector de ataque</i>                    | Manipulación de logs tiene acceso con privilegios elevados para borrar, cifrar o modificar los registros de auditoría del sistema.                                                                                         |
| <i>Impacto técnico/operativo</i>           | Imposibilidad de realizar un análisis forense, pérdida de validez legal de las pruebas y falta de aprendizaje post-incidente.                                                                                              |
| <i>Medida de control recomendada</i>       | Centralized Logging , enviar los registros en tiempo real a un servidor externo seguro (WORM) para que no puedan ser alterados localmente.                                                                                 |



### Escenario 08.

Una actualización mal ejecutada provocó la caída simultánea de múltiples servicios críticos a nivel global. Aunque no existió un atacante, el servicio de disponibilidad fue gravemente afectado. El RFC 4949 contempla estos eventos como operational failure, recordando que la seguridad también se ve afectada por errores internos. La falta de pruebas previas y planes de reversión amplificó el impacto.

| <i><b>Elemento</b></i>                     | <b>Respuesta</b>                                                                                                                                                                                |
|--------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Disponibilidad                                                                                                                                                                                  |
| <i>Definicion(es) aplicable(s) RFC4949</i> | <b>Operational Failure:</b> Fallo interno en los procesos o sistemas de la organización.<br><b>Disruption:</b> Interrupción de la operación normal del sistema debido a un evento no malicioso. |
| <i>Tipo de amenaza</i>                     | <b>Interna:</b> No hay intención de daño; es el resultado de una ejecución errónea de un proceso técnico.                                                                                       |
| <i>Vector de ataque</i>                    | Implementación de software o configuración sin validación suficiente en entornos de prueba                                                                                                      |
| <i>Impacto técnico/operativo</i>           | Caída global de servicios, pérdidas financieras inmediatas y daño a la confiabilidad de la infraestructura                                                                                      |
| <i>Medida de control recomendada</i>       | Capacidad de volver al estado anterior rápidamente y Pruebas en Staging (entornos espejo)                                                                                                       |

### Escenario 09.

Atacantes replicaron sitios y correos oficiales para engañar a ciudadanos y obtener información sensible. Este escenario afecta la autenticación, al suplantar identidades legítimas, y la confidencialidad de los datos recolectados. El RFC 4949 lo clasifica como masquerade y phishing, subrayando el componente de ingeniería social. La ausencia de mecanismos de autenticación del dominio y de concientización facilitó el éxito del ataque.

| <i><b>Elemento</b></i>                     | <b>Respuesta</b>                                                                       |
|--------------------------------------------|----------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Autenticación, Confidencialidad                                                        |
| <i>Definicion(es) aplicable(s) RFC4949</i> | <b>Masquerade:</b> Un usuario o sistema pretende ser otro para obtener acceso o datos. |

|                                      |                                                                                                                                                                             |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                      | <b>Phishing:</b> Técnica de ingeniería social para engañar y obtener secretos.<br><b>Ingeniería Social:</b> Manipulación psicológica de personas para que realicen acciones |
| <i>Tipo de amenaza</i>               | <b>Externa:</b> Atacantes externos que usan el engaño como arma principal.                                                                                                  |
| <i>Vector de ataque</i>              | Creación de sitios web espejo y correos electrónicos con dominios visualmente similares a los reales.                                                                       |
| <i>Impacto técnico/operativo</i>     | Robo masivo de identidades, fraude financiero y pérdida de confianza ciudadana en las plataformas oficiales.                                                                |
| <i>Medida de control recomendada</i> | Protocolos para evitar la suplantación de dominio. Concientización educación a los usuarios.                                                                                |

### Escenario 10.

En algunos incidentes, tras exfiltrar información, los atacantes ejecutaron acciones destructivas para borrar sistemas completos y eliminar rastros. Se produce un compromiso total de la confidencialidad, la integridad y la disponibilidad, configurando uno de los peores escenarios posibles. El RFC 4949 describe este patrón como destructive attack, donde el objetivo no es solo el lucro, sino el daño irreversible. La detección tardía impidió cualquier contención efectiva.

| <b>Elemento</b>                            | <b>Respuesta</b>                                                                                                                                                                                                                                                                 |
|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Servicios X.800 comprometidos</i>       | Confidencialidad, Integridad y Disponibilidad.                                                                                                                                                                                                                                   |
| <i>Definicion(es) aplicable(s) RFC4949</i> | <b>Destructive Attack:</b> Ataque cuyo objetivo principal es dañar o destruir recursos, no solo robarlos.<br><b>Exfiltration:</b> Transferencia no autorizada de datos fuera de la red.<br><b>Purge/Wiping:</b> Eliminación definitiva de datos para que sean irre recuperables. |
| <i>Tipo de amenaza</i>                     | <b>Externa:</b> Generalmente ejecutada por grupos avanzados (APT) o estados-nación con fines de sabotaje                                                                                                                                                                         |

|                                      |                                                                                                                                     |
|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------|
| <i>Vector de ataque</i>              | Acceso con privilegios de administrador que permite ejecutar comandos de borrado masivo en toda la red.                             |
| <i>Impacto técnico/operativo</i>     | Pérdida total de activos digitales y capacidad operativa. El daño es irreversible si no existen respaldos fuera de línea.           |
| <i>Medida de control recomendada</i> | Detección temprana y Segmentación de Red, para evitar que el ataque se propague a todos los sistemas y detenerlo antes del borrado. |

## Conclusiones:

Después de analizar estos 10 casos, me doy cuenta de que la seguridad informática es mucho más que solo poner un antivirus. Aquí mis conclusiones principales:

Primero, queda claro que los ataques ya no son simples. Antes quizás solo te borraban un archivo, pero hoy, como vimos con LockBit o los ataques destructivos, los hackers primero te roban la información, luego te cifran todo y al final hasta borran los registros para que no sepas ni quién fue. Atacan los tres pilares (Confidencialidad, Integridad y Disponibilidad) al mismo tiempo para dejarte sin salida.

Segundo, aprendí que el enemigo no siempre viene de fuera. A veces el problema es un error de un administrador que dejó una base de datos abierta en la nube o un empleado que decide vender información. Incluso un error humano al actualizar un sistema puede ser tan dañino como un virus, porque al final del día el servicio se cae igual.

## Referencias:

Internet Engineering Task Force (IETF). (2007). RFC 4949: Internet Security Glossary, Version 2. <https://datatracker.ietf.org/doc/html/rfc4949>

International Telecommunication Union – Telecommunication Standardization Sector (ITU-T). (1991). Recommendation X.800: Security Architecture for Open Systems Interconnection. <https://www.itu.int/rec/T-REC-X.800-199103-I/en>

